SC4063 Network Security

Group Report

Group No: 5

Full Name	Matriculation Number
Aaron Toh Sheng Rong	U2222943E
Koh Junyang Nicholas	U2222992D
Kuan Hong Hui Joy	U2221261D
Jasmine Tye Jia Wen	U2321408J
Liu Cong	U2321782E
Phoebe Lee Jia Ying	U2223881K
Yong Yik Sheng	U2322759F
Tan Bao Chen, Jess	U2222331K
Ng Yao Hong	U2220975H
Tan Wu Ji	U2222584L
Ong Hong Xun	U2321248G
Ong Chun Wei	U2321759C

Date of Submission: [INSERT DATE]

Executive Summary

[TO BE COMPLETED — Write for non-technical C-suite stakeholders]

[Explain: what happened, how the attacker entered, impact on operations, key recommendations]

[Keep this to 1 page, high-level, no technical jargon]

Detailed Findings

Investigation Scope

- 9-day PCAP dataset (approximately 130 files) provided by client, captured from a network tap on the core switch
- No endpoint telemetry or host images were available
- Analysis based solely on network traffic (Phase 1 investigation)
- The PCAP covered the window leading up to the ransomware encryption event

Tools Used

- Wireshark — GUI-based packet analysis and deep packet inspection
- tshark — Command-line batch searches across all 130 PCAP files for targeted triage
- mergecap — Merging relevant PCAP subsets for focused analysis

[Add any additional tools your team used: Zeek, NetworkMiner, etc.]

PCAP Triage & File Selection Methodology

Challenge: 130 PCAP Files

The client provided a 9-day packet capture split across approximately 130 individual PCAP files, each several hundred megabytes in size. The total dataset was too large to merge into a single file. A targeted triage approach was therefore required to identify which specific files contained evidence relevant to each investigation area.

Approach: Targeted tshark Batch Searches

Rather than opening each file individually in Wireshark, the command-line tool tshark was used to run targeted display filters across all 130 files in batch. The general command pattern was:

for f in *.pcap; do echo "=== $f ===" && tshark -r "$f" -Y "<filter>" -c <limit>; done

The -c flag limited output to the first few matches per file, ensuring the search completed quickly. Files that produced output were identified as containing relevant traffic and were then merged for detailed Wireshark analysis.

Part C File Identification (Exfiltration)

Step 1: Raw String Search

Filter: grep -rl "temp\.sh" *.pcap | tee hits_tempsh2.txt

Result: Two PCAP files returned matches — 34936-sensor-250306-00002439_redacted.pcap and 34936-sensor-250306-00002440_redacted.pcap.

Step 2: Merge Relevant Files

Only the two identified files were merged using mergecap:

mergecap -w merged_two_files.pcap 34936-sensor-250306-00002439_redacted.pcap 34936-sensor-250306-00002440_redacted.pcap

Step 3: tshark and Wireshark Analysis

- dns.qry.name contains "temp.sh" and dns.flags.response == 1 — confirmed DNS resolution to 51.91.79.17
- tls.handshake.extensions_server_name contains "temp.sh" — confirmed TLS connections and extracted timestamps
- frame contains "temp.sh" with protocol and destination port fields — confirmed all traffic to temp.sh was HTTPS (port 443) with no plain HTTP
- ip.dst == 51.91.79.17 with -z conv,tcp — measured asymmetric data volume (~458 MB outbound)
- smb2.filename — extracted unique filenames accessed over SMB by the compromised host
- Searched for 7-Zip magic bytes (37:7a:bc:af:27:1c) in traffic from 10.128.239.57 — negative, consistent with local compression before encrypted upload

Part B File Identification (Lateral Movement)

Step 1: Scanning Search (Negative)

- tcp.dstport == 445 && tcp.flags.syn == 1 && tcp.flags.ack == 0 — No results
- tcp.dstport == 135 && tcp.flags.syn == 1 — No results
- samr — No results

Step 2: Broader SMB/DCERPC Search

Filter: ip.addr == 10.128.239.57 && dcerpc

Result: Four files identified containing DCERPC traffic from the compromised host.

Step 3: Merge and Analyze

The four files were merged into partb_merged.pcap and analyzed with drsuapi and protocol filters.

Assigned to: Jasmine, Chun Wei, Hong Xun (Team 2)

[TO BE COMPLETED BY TEAM 2]

[Explain: how attacker entered the network]

[Identify: compromised host, external IP address, timestamp of initial access]

[Note: The Lynx group is known for purchasing compromised credentials or exploiting public-facing services]

[Filter for: RDP/VPN traffic entering the network from external IPs]

[Look for: successful login followed by immediate change in traffic behavior]

[Include MITRE ATT&CK mapping]

[Note: 10.128.239.57 was confirmed as the compromised host based on Parts B and C analysis — this machine had RDP exposed to the internet with hundreds of external IPs connecting via RDP]

A. Initial Access (Patient Zero)

A.1 Pre-Access Exposure

Within the available dataset, the earliest **visible** compromise chain begins on 2025-03-01. Prior to confirmed initial access, **10.128.239.57** was publicly reachable on TCP/3389 and sustained heavy inbound probing from multiple external sources. Within a 15-minute window starting at **2025-03-01T18:20:01Z**, Zeek recorded 9,669 inbound RDP events from 76 unique external IPs. As shown in Figure 1, the inbound RDP attempts were not uniformly distributed. They arrived in concentrated bursts by minute, which is characteristic of automated scanning tooling rather than manual access attempts. This volume and burst pattern is inconsistent with routine administrative access.

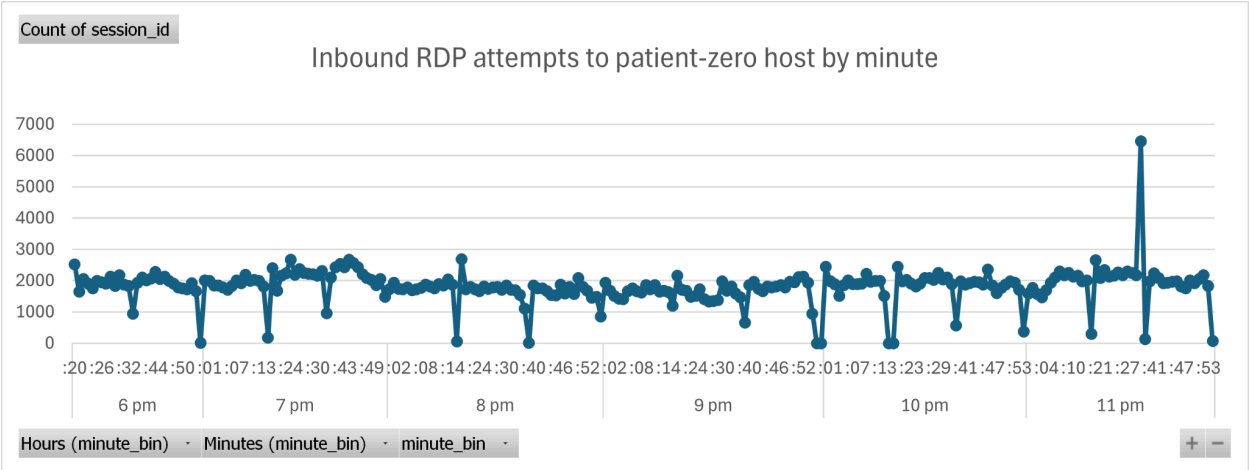


Figure 1: Inbound RDP attempts to patient-zero host by minute.

Packet-level analysis further confirms that **10.128.239.57** was actively receiving inbound RDP connections from multiple external IP addresses. As shown in Figure 2, Wireshark captures reveal TLS-encrypted traffic on TCP port 3389 between **10.128.239.57** and several external hosts, including **88.214.25.115** and **147.45.112.103**. The presence of repeated short-lived connections is consistent with automated probing or credential-spraying activity targeting the exposed RDP service.

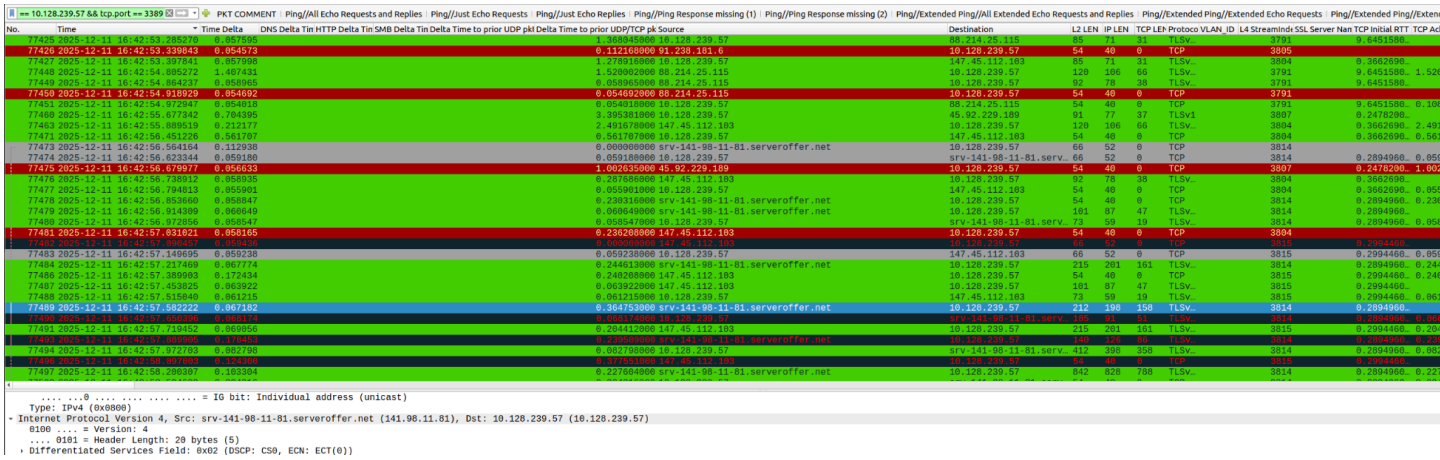


Figure 2: Wireshark capture showing inbound TLS-encrypted RDP traffic (TCP/3389) between external IP addresses and 10.128.239.57, confirming exposure and active probing of the RDP service.

Figure 3 further illustrates the breadth of the campaign by showing the top 15 external source IPs by hit count. The concentration of attempts across a small number of sources with the top five sources alone accounting for over 5,800 hits, suggesting organised, infrastructure-backed probing rather than opportunistic internet noise. Notably, **194.0.234.17**, geolocated to Iran (ASN 214295, Skynet Network Ltd), appears among the top sources and was also the first external IP to establish a TLS-confirmed session against .**57:3389** at 18:20:01Z.

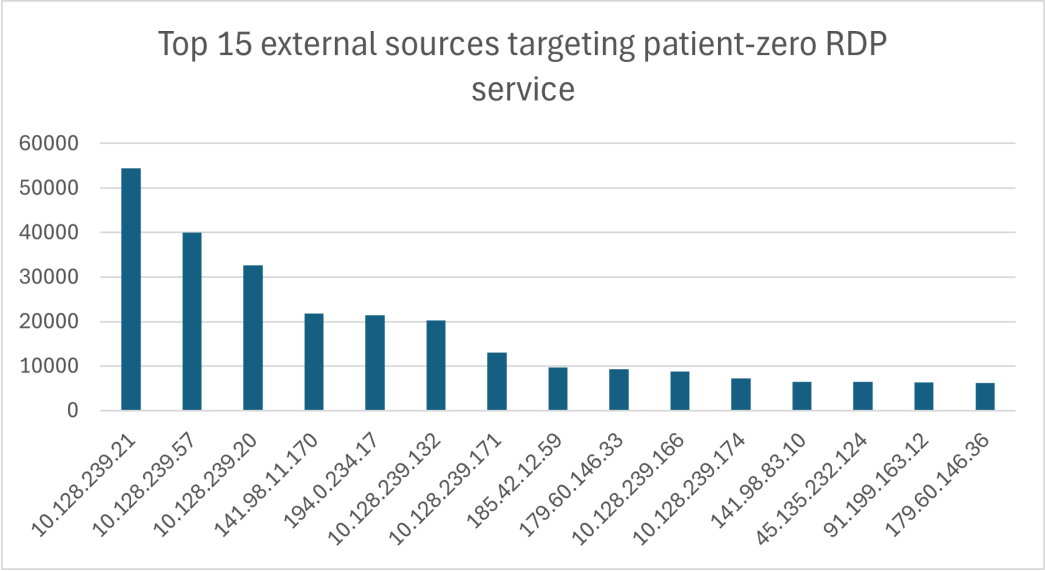


Figure 3: Top 15 external sources targeting patient-zero RDP service.

The following Zeek RDP records from the probing window illustrate the credential-spraying pattern, with multiple external sources attempting logins using common username cookies within seconds of each other:

Timestamp	Source IP	RDP Cookie (username hint)	Note
2025-03-01T20:06:30.306Z	185.147.124.177	user	Generic probe
2025-03-01T20:06:31Z	194.0.234.17	ecoborrow	Earlier Iran-origin probe
2025-03-01T20:06:31Z	91.199.163.12	administr	Admin credential attempt
2025-03-01T20:06:31Z	141.98.11.170	Admin	Admin credential attempt

The presence of username-like cookie values (**administr, Admin, ecoborrow**) across multiple sources within the same second confirms this was not incidental internet noise but an active, coordinated credential-abuse campaign targeting 10.128.239.57.

A.2 Confirming Initial Access

Most inbound sessions to **10.128.239.57** during this window were short-lived probe connections of a few KB and under 3 seconds, consistent with opportunistic scanning. A representative

example is 141.98.11.170 → 10.128.239.57:3389, which transferred only 3,899 bytes over 2.20 seconds, far below any threshold for an interactive session.

The session from 96.126.120.149 stands out materially. It produced a distinct three-event sequence across multiple Zeek log types indicating session escalation:

Timestamp	Log Type	Details
2025-03-01T20:07:47.477Z	zeek.rdp	result=encrypted, security_protocol=HYBRID indicate RDP negotiation succeeds
2025-03-01T20:07:47.521Z	zeek.ssl	Matching TLS record, handshake confirmed
2025-03-01T20:07:57.428Z	zeek.connection	1,091,450 bytes, 1,091 packets in 14.59s, indicating an interactive session
2025-03-01T20:07:57.491Z	zeek.rdp	result=encrypted, security_protocol=SSL, RDP layer confirmed
2025-03-01T20:07:57.536Z	zeek.ssl	Matching TLS record - session verified across three log types

The approximately 10-second gap between the HYBRID negotiation at **2025-03-01T20:07:47Z** and the full data session at **2025-03-01T20:07:57Z** is consistent with an RDP authentication handshake completed before an interactive desktop session begins.

No other external source in the capture window produced a corroborated three-log-type sequence of comparable volume or duration. This is the strongest candidate for the successful operator session.

Within the available Zeek dataset, the 18:20 UTC chain represents the earliest visible foothold behavior, while the 20:07 UTC session remains the strongest single external-source candidate for an operator-driven interactive session. Earlier pre-capture activity cannot be excluded.

Two important access windows were identified. The **18:20 UTC** window represents the earliest visible transition from inbound RDP activity to internal authentication behavior on **10.128.239.57**, while the **20:07 UTC** session remains the strongest single external-source candidate based on session size, duration, and corroboration across multiple Zeek log types.

Those are strong indicators that the host was exposed and being credential-tested. The session that stands out from this background is **96.126.120.149**, after comparing with zeek logs.

A.3 Patient Zero Determination

Patient zero is assessed as **10.128.239.57**. The post-access behaviour shift is the key evidence, within seconds to minutes of the large RDP session establishing, the same host began initiating internal Windows domain traffic it had no reason to generate under normal operation. The following timeline represents the earliest visible compromise chain based on Zeek network telemetry:

Timestamp (UTC)	Event	Source -> Destination	Key Evidence
2025-03-01T 18:20:01.130 Z	Earliest inbound RDP to patient zero	194.0.234.17:10897 -> 10.128.239.57:3389	direction=inbound, event_group=RDP_Ingress, session_id=Can7G94c5SO0L SvlU5
2025-03-01 18:20:01.283 Z	RDP, result: "encrypted", security_proto col: "HYBRID"	194.0.234.17 -> 10.128.239.57:3389	Inbound RDP progressed to encrypted negotiation stage
2025-03-01 18:20:01.315 Z	DCE/RPC Netlogon, NetrLogonSa mLogonEx	10.128.239.57 -> 10.128.239.29:49668	Immediate internal authentication-related activity
2025-03-01T 18:20:01.442 Z	Inbound RDP with TLS established	194.0.234.17:10897 -> 10.128.239.57:3389	tls_established=True on same session family
2025-03-01T 18:20:01.862 Z–18:20:07. 478Z	Repeated NetrLogonSa mLogonEx	10.128.239.57 -> 10.128.239.29	Sustained Netlogon activity in same early access window
2025-03-01T 18:24:08.280 Z	LDAP to likely DC	10.128.239.57:64781 -> 10.128.239.29:389	event_group=LDAP
2025-03-01T 18:24:08.322 Z	SMB to likely DC	10.128.239.57:56527 -> 10.128.239.29:445	event_group=SMB
2025-03-01T 18:24:08.336 Z	SMB file operation	10.128.239.57:56527 -> 10.128.239.29:445	event_action=SMB::FILE_OP EN, same SMB session
2025-03-01T 18:24:08.391 Z	RPC endpoint map	10.128.239.57:56528 -> 10.128.239.29:135	dce_operation=ept_map
2025-03-01T 20:08:00.307 Z	Netlogon RPC	10.128.239.57:56029 -> 10.128.239.29:49668	dce_operation=NetrLogonSa mLogonEx, session_id=CHuRB91urgWzH 8RjYf
2025-03-01T 20:08:01.023 Z	Second Netlogon call	10.128.239.57:56029 -> 10.128.239.29:49668	Same session_id=CHuRB91urgWzH 8RjYf

2025-03-01T 20:08:01.167 Z	DNS from patient zero	10.128.239.57:57606 -> 10.128.239.20:53	DNS event exists
2025-03-01T 20:08:01.294 Z	HTTP POST outbound	10.128.239.57:56833 -> 23.222.22.11:80	event_action=post, session_id=CTSYvL1yocmbBymRXk
2025-03-01T 23:30:49.510 Z	MSSQL probe	10.128.239.57:58061 -> 10.128.239.130:1433	Single internal probe observed
2025-03-01T 23:30:38Z–23:30:59Z	Privileged SMB access to likely DC	10.128.239.57 -> 10.128.239.29:445	ADMIN$, C$, and IPC$ mapped; file \\10.128.239.29\C$\delete.me opened and deleted

Additional Zeek correlation showed an even earlier and stronger behavior shift on 1 March 2025 at 18:20 UTC. The earliest observed inbound RDP-related contact occurred at 18:20:01.130Z. At 18:20:01.283Z, inbound RDP activity to **10.128.239.57:3389** was recorded with result: "encrypted" and security_protocol: "HYBRID". At 18:20:01.315Z, within the same second, **10.128.239.57** initiated internal Netlogon DCE/RPC activity to **10.128.239.29**, specifically NetrLogonSamLogonEx. The near-instant transition (within ~30 ms) from inbound RDP activity to internal Netlogon authentication behavior strongly indicates that 10.128.239.57 had already become an active foothold rather than a passively scanned host.

Packet-level validation was performed using Wireshark. As shown in Figure 4, filtering traffic between **10.128.239.57** and **10.128.239.29** reveals sustained bidirectional DCE/RPC communication. Notably, multiple NetrLogonSamLogonEx requests are observed, confirming that the compromised host was actively performing domain authentication operations. This corroborates the Zeek-derived timeline and validates that the observed behaviour is present in raw packet data rather than being an artefact of log processing.

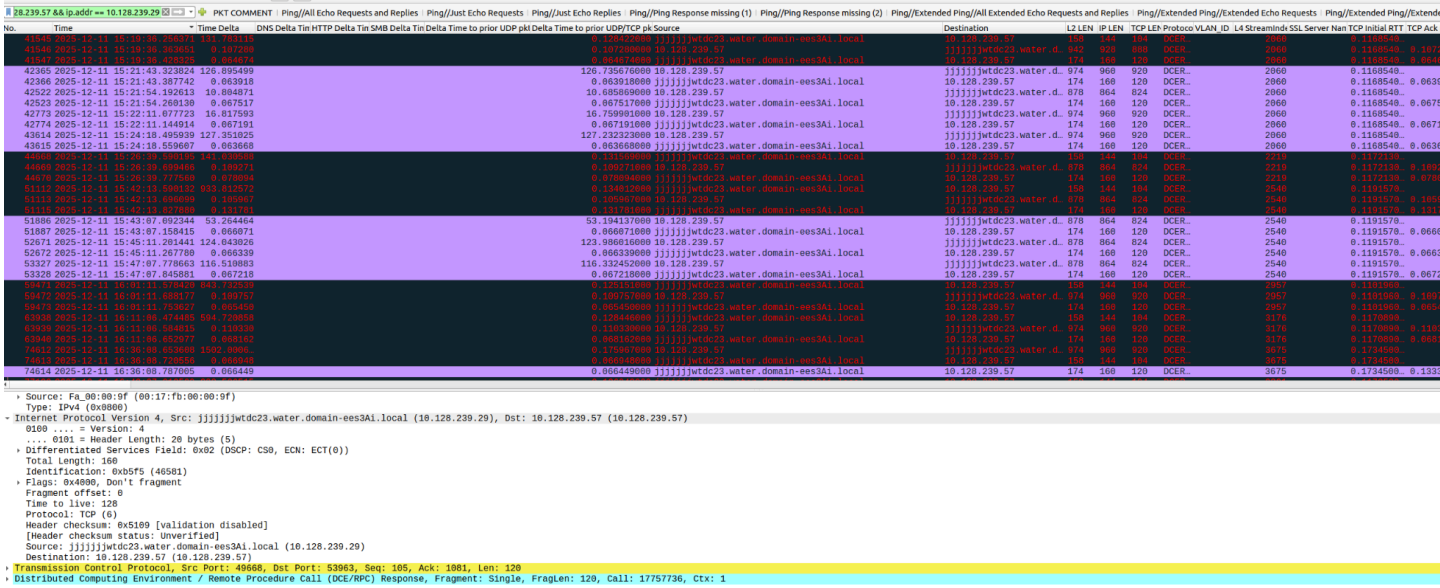


Figure 4: Wireshark capture showing sustained DCE/RPC Netlogon (NetrLogonSamLogonEx) traffic between 10.128.239.57 and 10.128.239.29, confirming active domain authentication following initial access.

At 18:20:01.442Z, TLS establishment on the RDP service was also recorded. This same-second progression materially strengthens the case that **10.128.239.57** was not merely scanned, but had already become an active foothold. Subsequent correlation further strengthens this assessment. After the initial Netlogon activity, **10.128.239.57** repeatedly performed Kerberos-associated SMB access to **10.128.239.29**, including IPC$ mappings, SYSVOL reads, and later ADMIN$ / C$ access with an observed **C$\delete.me** open/delete sequence. The observed **\\10.128.239.29\C$\delete.me** open/delete sequence is particularly significant. Unlike IPC$ or SYSVOL access, which may occur during normal domain operations, access to ADMIN$ and C$ shares combined with file create/delete behaviour strongly indicates successful authenticated write capability. This is consistent with an attacker validating administrative access or testing lateral movement execution capability.

Further packet-level analysis reveals that the delete.me file operation was not isolated to a single host. Instead, **10.128.239.57** performed repeated delete.me operations across a large number of distinct internal systems, as observed in multiple PCAP files (e.g. 34936-sensor-250301-00002370 and 00002371).
The activity involves 133 unique destination hosts, indicating that this behaviour was automated rather than manual. The repeated use of a consistent filename across many systems strongly suggests that delete.me was used as a marker or test file to verify administrative write access via SMB shares such as ADMIN$ and C$.
This pattern is characteristic of attacker-driven lateral movement or propagation, where an established foothold is used to systematically validate access across the network. The scale and consistency of this behaviour significantly strengthened the conclusion that **10.128.239.57** had transitioned from initial compromise to active internal operation.

Figure 5 visualises this behaviour shift directly. Prior to the RDP session, **10.128.239.57** appeared exclusively as a destination in inbound traffic. Immediately after, it transitioned to a source of outbound internal traffic, initiating LDAP, SMB, DCE/RPC, DNS, and HTTP connections it had no prior history of generating. This protocol mix is precisely what is expected when an attacker gains an interactive foothold and begins manual discovery of the internal environment.

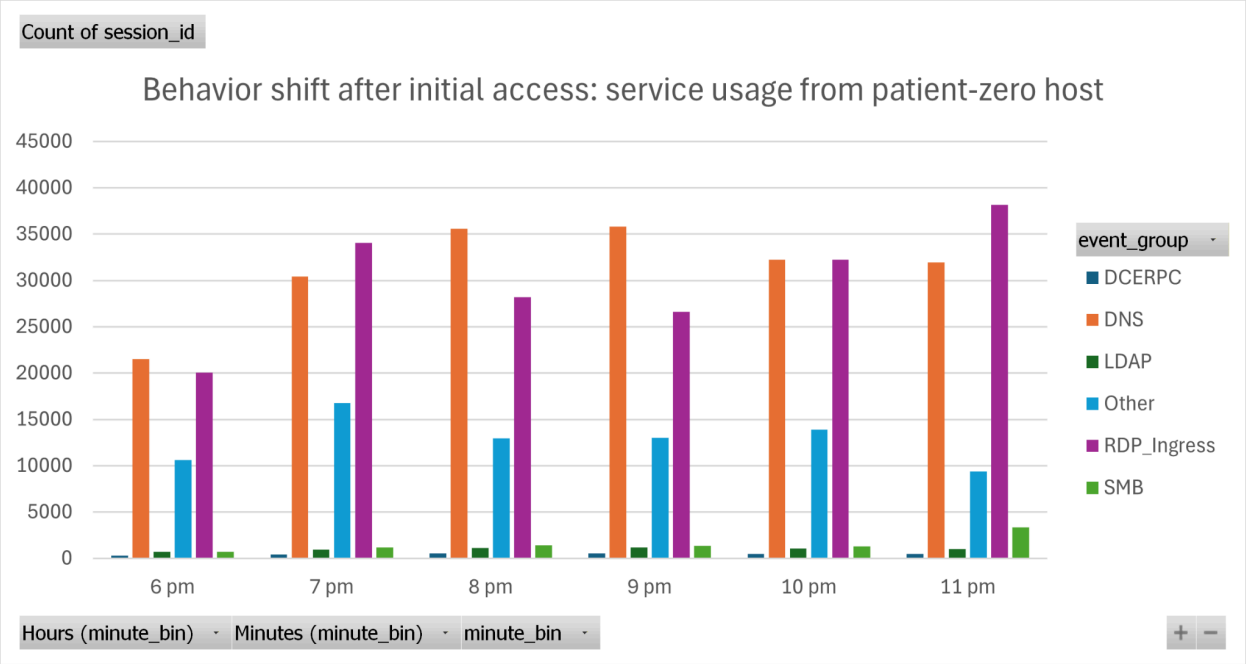


Figure 5: Behavior shift after initial access: service usage from patient-zero host.

The near-instant transition from inbound RDP to internal Netlogon, LDAP, SMB, and RPC activity is the critical evidentiary link. A host that was merely being scanned externally would not immediately begin Windows domain authentication operations against **10.128.239.29**. This sequence is consistent only with an attacker who had gained interactive access and was conducting internal discovery.

A.4 Reasoning

The strongest host-level compromise chain begins at 18:20 UTC on 1 March 2025, when **10.128.239.57** transitions almost immediately from inbound RDP activity to internal Netlogon authentication behavior, while the 20:07 UTC session remains the strongest single external-source candidate for the operator's interactive access.

That is why it is the best candidate for the actual operator session. This combination is more consistent with a successful interactive foothold than with routine internet scanning alone.

Although the exact credential used and the exact successful external source IP cannot be proven from network telemetry alone, the strongest available evidence supports **10.128.239.57** as the earliest compromised internal foothold.

No other internal host in the provided dataset shows an equally early and tightly coupled sequence of external remote-access exposure followed immediately by high-volume domain-authentication activity, making 10.128.239.57 the strongest patient-zero candidate within the observed window.

B. Lateral Movement & Discovery

Assigned to: Phoebe, Yik Sheng, Liu Cong (Team 3)

B.1 Overview

Following initial access via RDP on host 10.128.239.57, the attacker conducted extensive lateral movement across the internal network using SMB2 and RDP protocols. Zeek log analysis identified SMB connections from the compromised host to 153 unique internal targets across the 10.128.239.0/24 subnet, as well as RDP sessions to 6 machines for interactive remote access. The SMB lateral movement occurred across three distinct scanning waves: March 1 (2,060 connections), March 6 (5,956 connections — largest wave), and March 8 (3,023 connections), totaling 14,646 SMB connection attempts.

B.2 Findings

B.2.1 SMB2 Lateral Movement

Zeek SMB logs confirm that compromised host 10.128.239.57 established SMB connections to 153 unique internal targets. The scanning pattern was RANDOM/SCATTERED rather than sequential, characteristic of NetExec (formerly CrackMapExec) — a parallel threaded SAMR-based enumeration tool. Target hosts ranged from 10.128.239.1 to .226 in a non-sequential pattern (.176, .21, .34, .177, .51...). This widespread access was driven by SAMR-based enumeration (see B.2.4) which runs over SMB named pipes, as well as direct file share access for data staging. The table below summarises the key destination groups by role.

Destination IP	Protocols Observed	Possible Role
10.128.239.20–21	SMB2, SAMR, DCERPC	Root Domain DCs (domain-ees3Ai.local)

10.128.239.22, .27	SMB2, SAMR	ADMIN Domain DCs
10.128.239.23, .29	SMB2, SAMR, DCERPC	WATER Domain DCs (heavy group enumeration)
10.128.239.24–26, .28, .30–33	SMB2, SAMR, DCERPC, DCOM	Servers (infrastructure)
10.128.239.34–39	SMB2, RDP, RDPUDP	Servers (RDP + SMB lateral movement)
10.128.239.42–52, .54–56, .58–99	SMB2, SAMR	Workstations/Servers (SAMR enumeration)
10.128.239.100–149	SMB2, SAMR	Workstations (SAMR enumeration)
10.128.239.150–156, .159–160, .162–163	SMB2, SAMR	Servers
10.128.239.176–177	SMB2, SAMR, RDP, SRVSVC	Servers (RDP + share enumeration)

B.2.2 RDP Lateral Movement

- The attacker used RDP from 10.128.239.57 to the following internal hosts for interactive remote access:
- • 10.128.239.34 — RDP, RDPUDP, RDPUDP2, TLSv1.2
- • 10.128.239.35 — RDP, RDPUDP, RDPUDP2, TLSv1.2
- • 10.128.239.36 — RDP, RDPUDP, RDPUDP2, TLSv1.2
- • 10.128.239.37 — RDP, RDPUDP, RDPUDP2, TLSv1.2
- • 10.128.239.39 — RDP, RDPUDP, RDPUDP2, TLSv1.2
- • 10.128.239.176 — RDP, SRVSVC, TLSv1.2

•

B.2.3 Additional Discovery Activity

SRVSVC (Server Service Remote Protocol): Traffic from 10.128.239.57 to 10.128.239.176 using the SRVSVC interface was observed, indicating the attacker enumerated network shares (MITRE T1135 — Network Share Discovery).

DCOM Execution: IOXIDResolver and ISystemActivator traffic from 10.128.239.57 to 10.128.239.32, suggesting DCOM-based remote code execution (MITRE T1021.003).

DRSUAPI/Active Directory Queries: The compromised host performed DsBind, DsCrackNames, and DsUnbind against WATER domain DCs (10.128.239.23, 10.128.239.29). These are normal domain-joined computer operations confirming the host was authenticated to the domain.

B.2.4 Network Scanning — SAMR-Based Enumeration Detected

Analysis of Zeek sensor logs (dce_rpc.log and smb.log) revealed extensive network enumeration originating from compromised host 10.128.239.57. The attacker generated 14,646 total SMB connections (port 445) across the 10.128.239.0/24 subnet targeting 153 unique internal hosts, of which 1,444 were SAMR enumeration operations (targeting 130 unique hosts). The primary SAMR operation used was SamrLookupDomainInSamServer (261 calls), consistent with tools such as NetExec (formerly CrackMapExec) or SoftPerfect Network Scanner. Three distinct scanning waves were identified across the capture window. While no traditional SYN-based port scanning (ports 445, 135) was detected in the PCAPs, the SAMR enumeration served the same reconnaissance purpose — mapping live hosts and querying domain membership across the entire subnet.

Table B1: SMB Scanning Waves

Wave	Date	Time (UTC)	Connections	Notes
1	March 1, 2025	~23:30	2,060	Initial subnet reconnaissance
2	March 6, 2025	~22:50	**5,956**	**Largest wave** — comprehensive enumeration
3	March 8, 2025	~08:22	3,023	Final scanning phase
Total	March 1–8, 2025	—	**14,646**	153 unique targets (.1 to .226)

Scan characteristics: RANDOM/SCATTERED pattern (not sequential), targeting .176, .21, .34, .177, .51, etc. This behavior is consistent with NetExec's parallel threaded SAMR-based enumeration rather than linear port scanning. This activity corresponds to MITRE ATT&CK T1018 (Remote System Discovery) and T1087.002 (Domain Account Discovery).

B.2.5 Account and Group Enumeration via SAMR

Zeek dce_rpc logs confirmed **243,642 total DCE-RPC operations** during the capture window, with the compromised host generating significant authentication and enumeration activity across multiple Active Directory domains.

Table B2: DCE-RPC Operations Summary

Operation	Count	Target(s)	Purpose	MITRE ATT&CK
NetrLogonSamLogonEx	**240,175**	DCs .29 (236,198) + .23 (3,977)	Domain authentication for lateral movement	T1078/T1078.002
NetrShareEnum	274	Multiple hosts	Network share discovery	T1135
DRSCrackNames	269	DCs .23, .29	Active Directory name resolution	—
DRSBind	299	DCs .23, .29	Directory Replication Service binding	—
SamrLookupDomainInSamServer	261	153 unique hosts	Domain membership discovery	T1018
SamrOpenGroup	155	DCs .23, .29 (WATER)	Group enumeration	T1069.002
SamrGetMembersInGroup	92	DCs .23, .29 (WATER)	Group membership discovery (Domain Admins)	T1069.002

Total: **243,642 DCE-RPC operations** across the capture window.

Table B3: Domain Controller Activity

Domain Controller	Domain	SMB Sessions	Auth Operations	Role	First Contact
10.128.239.29	WATER	1,637	**236,198**	Primary DC	2025-03-01 18:24:08Z **(4 min after**

Domain Controller	Domain	SMB Sessions	Auth Operations	Role	First Contact
					initial access)
10.128.239.23	WATER	—	3,977	Secondary DC	2025-03-01 20:02:12Z (first in subnet scan)
10.128.239.20	Root (domain-ees3Ai.local)	—	—	DC + DNS	—
10.128.239.21	Root (domain-ees3Ai.local)	—	—	DC + DNS	—
10.128.239.22	ADMIN	—	—	DC	—
10.128.239.27	ADMIN	—	—	DC	—

Account Creation: No SamrCreateUser2InDomain or SamrAddMemberToGroup operations were detected, confirming the attacker operated exclusively using existing compromised credentials obtained prior to initial access. The extensive group enumeration activity (155 SamrOpenGroup + 92 SamrGetMembersInGroup operations) indicates the attacker was identifying privileged accounts (e.g., Domain Admins) for lateral movement and privilege escalation.

B.3 Domain Infrastructure

DNS SRV records for _ldap._tcp revealed a multi-domain Active Directory forest:

Domain	Hostname	IP Address	Role
domain-ees3Ai.local (root)	jjjjjjjdc1	10.128.239.20	DC + DNS
domain-ees3Ai.local (root)	jjjjjjjdc3	10.128.239.21	DC + DNS
ADMIN.domain-ees3Ai.local	jjjjjjjaddc5	10.128.239.22	DC

ADMIN.domain-ees3Ai.local	jjjjjjjaddc7	10.128.239.27	DC
WATER.domain-ees3Ai.local	jjjjjjjwtdc23	10.128.239.29	DC
WATER.domain-ees3Ai.local	jjjjjjjwtdc8	10.128.239.23	DC

B. Lateral Movement & Discovery — PCAP Cross-Validation

To validate the Zeek-based findings presented in Section B, targeted PCAP analysis was performed using tshark across the 130 capture files (~70 GB). The following sections present the PCAP evidence corresponding to each key Zeek finding.

B.4 PCAP Verification of SAMR Scanning Waves

PCAP files for March 1, 6, and 8 were filtered using tshark with the display filter “ip.src == 10.128.239.57 && samr” to extract all SAMR protocol traffic originating from the compromised host. The results confirm the three scanning waves identified in the Zeek analysis.

Wave	SAMR Packets (PCAP)	Unique Targets (PCAP)	Zeek Comparison
Wave 1 (March 1)	967	131	244 Zeek SAMR entries — Confirmed
Wave 2 (March 6)	898	125	631 Zeek SAMR entries — Confirmed
Wave 3 (March 8)	1,674	134	562 Zeek SAMR entries — Confirmed

Note: PCAP packet counts are higher than Zeek entry counts because Zeek logs one entry per SAMR operation, while the PCAP captures multiple packets per operation (request, response, and TCP acknowledgements). The key validation metric is the number of unique targets, which is consistent across both data sources.

B.5 PCAP Verification of RDP Lateral Movement and Scanning

March 8 PCAP files were filtered using tshark with the display filter “ip.src == 10.128.239.57 && tcp.dstport == 3389 && tcp.flags.syn == 1 && !(tcp.flags.ack == 1)” to extract all outbound RDP SYN packets from the compromised host.

Results: 514 RDP SYN packets were captured, targeting 153 unique internal hosts. All 6 RDP targets identified in the Zeek analysis (10.128.239.34, .35, .36, .37, .39, .176) were confirmed. Critically, the PCAP analysis revealed that the attacker also conducted RDP port scanning across the entire subnet — 147 additional hosts received single RDP SYN probes (1 packet each), indicating the attacker was identifying which hosts had RDP enabled. Hosts in the .164–.175, .180, .221–.222, and .225–.226 ranges received multiple SYN retries (5 packets each), suggesting these hosts were unresponsive but repeatedly probed. This RDP scanning activity constitutes additional evidence of network reconnaissance (MITRE ATT&CK T1018) not previously captured in the Zeek-only analysis.

B.6 PCAP Verification of Account Creation (Negative)

All March 8 PCAP files were searched for SamrCreateUser2InDomain operations using the tshark filter “ip.src == 10.128.239.57 && samr.samr_CreateUser2InDomain”. Zero matching packets were found. This confirms the Zeek finding that no user accounts were created via SAMR during the capture window, and the attacker operated exclusively using existing compromised credentials.

B.7 PCAP Cross-Validation Summary

All key Zeek findings for Part B were independently corroborated by targeted PCAP analysis using tshark. The three SAMR scanning waves (March 1, 6, 8) were confirmed with consistent unique target counts across both data sources. The 6 RDP lateral movement targets were confirmed, and additional RDP port scanning activity (153 unique targets) was discovered that was not visible in the Zeek logs alone. The absence of account creation operations was verified. The PCAP evidence strengthens the confidence level of the Zeek-based investigation and provides raw packet-level proof to support the forensic conclusions presented in Sections B.2.1 through B.2.5.

C. Data Exfiltration (Double Extortion)

Assigned to: Phoebe, Yik Sheng, Liu Cong (Team 3)

C.1 Overview

Investigation of the 130-file PCAP dataset confirmed that the compromised host 10.128.239.57 exfiltrated approximately 1.03 GB of data to temp.sh (51.91.79.17) over encrypted TLS 1.3 (HTTPS, port 443) across three upload phases spanning November 21, 2025 to January 27, 2026. The exfiltration followed a staged approach: data was first collected from internal file servers via SMB by 10.128.239.37, compressed into .7z archives, transferred to 10.128.239.57 as the upload relay, and finally uploaded to temp.sh. Because all uploads used TLS 1.3 encryption, direct payload inspection was not possible; however, DNS, TLS SNI, SMB filename, and connection volume evidence collectively provide strong proof of the exfiltration chain. This activity is consistent with Lynx’s known double-extortion methodology.

C.2 Exfiltration Destination Identification

A raw string search across all 130 PCAP files identified files containing the string “temp.sh”:

Initial result: 2 files (00002439, 00002440). A subsequent loop across all 130 files filtering for traffic to 51.91.79.17 (resolved IP of temp.sh, confirmed via DNS) identified a third file (00002441). File 00002441 was missed by the grep search because by that point the TLS session was already established — the SNI hostname only appears in the initial ClientHello handshake. All three files were merged for consolidated analysis:

Entity / IP	Role
10.128.239.57	Internal compromised host (upload relay) — sole host communicating with temp.sh
10.128.239.37	Internal file server — data collection and .7z compression source
51.91.79.17	External temp.sh exfiltration server
temp.sh	File-sharing service confirmed via DNS resolution and TLS SNI field

Table C2: Key network entities involved in the exfiltration chain.

C.3 DNS Resolution Evidence

DNS queries confirmed temp.sh resolved to 51.91.79.17 across multiple sessions:

Filter: dns.qry.name contains "temp.sh" and dns.flags.response == 1

Timestamp (UTC+8)	Querying Host	Resolved IP	Note
2025-11-21 16:14:54	10.128.239.21 (internal DNS)	51.91.79.17	Phase 1 — DNS server resolves for internal hosts
2025-11-21 16:17:08	10.128.239.57 + 10.128.239.21	51.91.79.17	Phase 1 — .57 directly listed as querying host ✔
2025-11-21 22:04:56	10.128.239.21 (internal DNS)	51.91.79.17	Phase 1 — evening session re-resolution
2026-01-27 10:34:22	10.128.239.57 + 10.128.239.20	51.91.79.17	Phase 3 — .57 directly listed as querying host ✔
2026-01-27 10:35:29	10.128.239.21 (internal DNS)	51.91.79.17	Phase 3 — morning session DNS resolution

Table C3: DNS resolution evidence. Rows marked ✔ where 10.128.239.57 appears as querying host directly confirm the compromised host initiated the temp.sh lookup.

C.4 TLS Connection Evidence

11 TLS 1.3 ClientHello sessions with SNI=temp.sh were confirmed from 10.128.239.57 to 51.91.79.17:

#	Timestamp (UTC+8)	Source	Destination	Upload Phase
1	2025-11-21 16:14:58	10.128.239.57	51.91.79.17	Phase 1 — Afternoon
2	2025-11-21 16:17:43	10.128.239.57	51.91.79.17	Phase 1 — Afternoon
3	2025-11-21 22:02:19	10.128.239.57	51.91.79.17	Phase 1 — Evening

4	2025-11-21 22:02:20	10.128.239.57	51.91.79.17	Phase 1 — Evening
5	2025-11-21 22:04:58	10.128.239.57	51.91.79.17	Phase 1 — Evening
6	2025-11-21 22:13:53	10.128.239.57	51.91.79.17	Phase 1 — Evening
7	2026-01-27 10:35:29	10.128.239.57	51.91.79.17	Phase 3 — Morning
8	2026-01-27 10:39:34	10.128.239.57	51.91.79.17	Phase 3 — Morning
9	2026-01-27 10:45:19	10.128.239.57	51.91.79.17	Phase 3 — Morning
10	2026-01-27 11:16:18	10.128.239.57	51.91.79.17	Phase 3 — Late Morning
11	2026-01-27 12:20:17	10.128.239.57	51.91.79.17	Phase 3 — Afternoon

Additionally, filter frame contains ".7z" and ip.src == 10.128.239.57 and ip.dst == 51.91.79.17 returned 34 matching packets across a second upload phase (Dec 19–20, 2025) not captured by the SNI filter. Filter frame contains ".zip" and ip.src == 10.128.239.57 and ip.dst == 51.91.79.17 returned 1 packet (Dec 19, 2025), consistent with a pre-existing zip archive being uploaded directly.

C.5 Data Volume Analysis

Field	Value
Address A (Source)	10.128.239.57
Address B (Destination)	51.91.79.17
Packets A→B (Outbound)	684,911
Bytes A→B (Outbound)	~1,033 MB (~1.03 GB)
Packets B→A (Inbound)	269,030
Bytes B→A (Inbound)	~15 MB (server acknowledgements only)
Total Packets	953,941
Duration	~67 days (5,795,104 seconds)
Protocol	TLS 1.3 / HTTPS port 443

Table C5: TShark IPv4 conversation statistics confirming ~1.03 GB outbound exfiltration. Note: Earlier estimate of ~458 MB was incomplete — file 00002441 contained additional exfiltration traffic.

C.6 Compression and Staging Evidence (.7z)

.7z archives were compressed on 10.128.239.37 (not 10.128.239.57 as originally assumed) and transferred to 10.128.239.57 via SMB port 445. Five SMB transfer events were confirmed:

Timestamp (UTC+8)	Source	Destination	Port	Note
2025-11-20 21:23:41	10.128.239.37	10.128.239.57	445 (SMB)	Batch 1 — Transfer 1
2025-11-21 00:52:40	10.128.239.37	10.128.239.57	445 (SMB)	Batch 1 — Transfer 2
2025-11-21 02:02:26	10.128.239.37	10.128.239.57	445 (SMB)	Batch 1 — Transfer 3
2026-01-27 03:09:05	10.128.239.37	10.128.239.57	445 (SMB)	Batch 2 — Transfer 1
2026-01-27 03:50:28	10.128.239.37	10.128.239.57	445 (SMB)	Batch 2 — Transfer 2

Table C6: .7z archive transfers from compression host (10.128.239.37) to upload relay (10.128.239.57) via SMB port 445.

C.7 SMB Data Collection Evidence

Filter: smb2.filename and (ip.src == 10.128.239.57 or ip.dst == 10.128.239.57)

Three phases of SMB data collection involving 10.128.239.57 were confirmed:

Phase	Date	Traffic Direction	Data Accessed
Phase 1	Nov 20–21, 2025	10.128.239.57 ↔ 10.128.239.37	GIS datasets, organizational documents, planning files (.geojson, .zip, .doc, .pdf)
Phase 2	Nov 22, 2025	10.128.239.29 → 10.128.239.57	AD GPO files from water.domain-ees3Ai.local (Groups.xml, Registry.xml, audit.csv)
Phase 3	Dec 20–21, 2025	10.128.239.57 ↔ 10.128.239.29	Additional GPO access — water domain policy files

Table C7: SMB data collection phases confirming what was staged before exfiltration.

The following data categories were confirmed accessed:

- GIS/Geographic Datasets: MO_County_Imagery_Index.geojson, MO_Public_School_Districts.geojson, MO_Missouri_Department_of_Conservation_Boat_Ramps.geojson, MO_NPDES_Animal_Feeding_Operations (.geojson/.csv/.kml/.zip), MO_Public_Drinking_Water_Districts.geojson, MO_Sales_Tax_Boundaries.geojson, MO_State_Boundary.geojson, MO_Wells.geojson/.csv, Parks.geojson/.kml, Street_Centerline.geojson/.zip, domainaaaaa_Zoning.zip
- Organizational/Administrative Documents: UseofForceDataElementsGuidelinesV.1.docx, The Missouri Legal Services Disaster Manual 3-14-2016.doc, SWPPP Template.doc, sample letter.docx, small-business.pdf, SECTION V.doc, MTP+bio.doc, seg_exhibit5.doc
- Parks and Conservation Materials: TNC_Whitepaper.pdf, NatureNeighborhoods_MoNativeWildflowerList.pdf, Show-Me_NaturalCommunities.pdf,

stateofunions.pdf, NANewsletter2010.pdf, NANewsletter2017.pdf, SouthernMO-TREX-2024-Announcement-1.pdf, Special_Management_Regulations.pdf, Statewide_2023_FINAL_WEB.pdf

- Financial/Regulatory Data: NG_CONS_SUM_DCU_SMO_M.xls, myb2-2014-mo.xls, parkwild_19452012_by_state.xls, sentinels_winners_1925.xls, table23.xls
- Active Directory Group Policy Objects (most sensitive): Groups.xml (may contain cPassword cached credentials), Registry.xml policy files, GptTmpl.inf security templates, audit.csv configurations from domain-ees3Ai.local (root), admin., parks., water., and safety. subdomains

Temporal correlation confirms the staged upload pattern: Batch 1 transfers (Nov 20–21, 21:23–02:02) preceded the first TLS upload to temp.sh (Nov 21, 16:14) by ~13 hours. Batch 2 transfers (Jan 27, 03:09–03:50) preceded the Jan 27 TLS upload (10:35) by ~7 hours, consistent with the attacker staging and verifying archives before uploading. 7-Zip magic bytes (37:7a:bc:af:27:1c) were not found in raw payloads as expected — .7z content was encrypted inside TLS 1.3 before transmission.

C.8 Complete Exfiltration Timeline

Timestamp (UTC+8)	Phase	Activity
Nov 20, 2025 21:38	Data Collection	10.128.239.57 begins SMB reads from file server 10.128.239.37 (GIS data, documents)
Nov 20–21, 2025 21:23–02:02	Compression + Staging	10.128.239.37 compresses data into .7z; transfers 3 archives to 10.128.239.57 via SMB port 445
Nov 21, 2025 16:14–22:13	Exfiltration Phase 1	10.128.239.57 uploads .7z archives to temp.sh:443 via TLS 1.3 — 6 confirmed sessions
Nov 22, 2025	Additional Collection	10.128.239.29 (Domain Controller) sends AD GPO files to 10.128.239.57 via SMB
Dec 19–20, 2025	Exfiltration Phase 2	Additional .7z uploads to temp.sh — confirmed by frame contains ".7z" filter (34 packets to 51.91.79.17:443)
Dec 20–21, 2025	Additional Collection	10.128.239.57 accesses water domain GPO files from 10.128.239.29
Jan 27, 2026 03:09–03:50	Compression + Staging	10.128.239.37 sends 2 final .7z archives to 10.128.239.57 via SMB port 445
Jan 27, 2026 10:35–12:20	Exfiltration Phase 3	10.128.239.57 uploads final .7z archives to temp.sh — 5 TLS sessions, bulk of ~1.03 GB total

Table C8: Complete exfiltration timeline from initial SMB data collection through final upload to temp.sh.

C.9 Encryption Limitations

All traffic to temp.sh used TLS 1.3 on port 443 exclusively — no plain HTTP uploads detected. 7-Zip magic bytes (hex: 37 7A BC AF 27 1C) were not recoverable from the encrypted payload, as expected with TLS 1.3. The .7z filename string was visible in SMB metadata (internal transfer between .37 and .57) and in TLS application data headers (temp.sh upload form fields), but file contents could not be directly inspected. The circumstantial evidence chain — SMB collection, .7z compression on 10.128.239.37, staging to 10.128.239.57, temporal correlation with TLS uploads, and ~1.03 GB asymmetric outbound volume — collectively provides strong proof of data exfiltration consistent with Lynx double-extortion operations.

ANOTHER VERSION

C. Data Exfiltration (Double Extortion) — Zeek Log Analysis

The following analysis is based on Zeek network log data.

C.1 Overview

Analysis of Zeek network logs confirms that the compromised host 10.128.239.57 performed large-scale data exfiltration to an external file-sharing service associated with temp.sh. The outbound transfer was directed to 51.91.79.17 over TLS/HTTPS on port 443, preventing direct inspection of payload contents. Zeek evidence independently supports the exfiltration chain through a combination of DNS resolution, TLS metadata, connection-level byte counts, and SMB staging activity. Collectively, these records provide strong evidence that approximately 1.03 GB of data was transmitted out of the network in a manner consistent with double-extortion ransomware operations.

C.2 Key Network Entities

Zeek DNS logs show that 10.128.239.57 resolved the domain temp.sh to 51.91.79.17 through internal DNS infrastructure. Zeek also preserves temp.sh in TLS metadata for at least one outbound encrypted session from 10.128.239.57 to 51.91.79.17:443, where the SSL/TLS record explicitly contains server.name = temp.sh. This confirms the domain-to-IP relationship at both the DNS and TLS layers.Accordingly, the attribution of the exfiltration destination to temp.sh / 51.91.79.17 is strongly supported by Zeek.

Table C2: Key Network Entities

Entity Type	IP Address	Description
Internal Host	10.128.239.57	Compromised host performing final outbound exfiltration
Internal Host	10.128.239.37	Internal host involved in staging-related SMB activity
External Server	51.91.79.17	Remote server hosting temp.sh
Domain	temp.sh	File-sharing service used for exfiltration

Table C2 identifies the key entities involved in the data exfiltration process.

C.3 Exfiltration Activity Timeline

Zeek shows that the exfiltration chain involved a close sequence of events in which 10.128.239.57 first resolved temp.sh, then established outbound TLS sessions to 51.91.79.17:443, followed by high-volume data transfer. Within the reviewed Zeek connection records, four major outbound TLS sessions from 10.128.239.57 to 51.91.79.17 account for the majority of the observed outbound volume.

At the same time, Zeek also shows related pre-exfiltration SMB activity involving internal hosts and archive-related file handling. This indicates that the outbound transfer was preceded by internal staging rather than representing ordinary browsing behavior.

Important note: Zeek strongly confirms the exfiltration event itself, but the multi-phase Nov/Dec/Jan reconstruction is more explicitly established by PCAP analysis. Zeek should therefore be used as strong corroboration of the exfiltration chain rather than as the sole source for the full long-range phased timeline.

Table C3: Zeek Exfiltration Sequence Summary

Event	Evidence
DNS resolution of temp.sh	10.128.239.57 resolved temp.sh to 51.91.79.17 through internal DNS
TLS session establishment	Outbound TLS sessions observed from 10.128.239.57 to 51.91.79.17:443
TLS metadata attribution	At least one SSL/TLS record contains server.name = temp.sh
High-volume outbound transfer	Four major TLS sessions together account for ~1.03 GB outbound
Pre-exfiltration staging	SMB activity shows internal share access, archive handling, and staging-related operations

Table C3 summarises the timeline of exfiltration activity.

C.4 Data Volume Analysis

Zeek connection logs (conn.log) reveal multiple high-volume outbound TLS sessions from 10.128.239.57 to 51.91.79.17:443. The major sessions identified in the reviewed data are approximately:

- 89,174,534 bytes
- 680,768,939 bytes
- 106,319,802 bytes
- 149,343,538 bytes

These sum to 1,025,606,813 bytes, or approximately 1.03 GB outbound. This volume is significantly higher than normal user web activity and strongly supports deliberate bulk exfiltration.

Table C4: Major Outbound TLS Sessions

Timestamp (UTC)	Source IP	Destination IP	Protocol	Bytes Sent (Source → Dest)
2025-03-06 23:41:12	10.128.239.57	51.91.79.17	TLS (443)	89,174,534 (~89 MB)
2025-03-06 23:41:54	10.128.239.57	51.91.79.17	TLS (443)	680,768,939 (~680 MB)
2025-03-06 23:42:06	10.128.239.57	51.91.79.17	TLS (443)	106,319,802 (~106 MB)
2025-03-06 23:42:18	10.128.239.57	51.91.79.17	TLS (443)	149,343,538 (~149 MB)
Total				**1,025,606,813 (~1.03 GB)**

Table C4 summarises the major outbound TLS sessions from the compromised host to the external exfiltration server.

C.5 Supporting Evidence: Data Staging via SMB

Zeek provides strong support that the exfiltration was preceded by internal SMB-based staging activity. Host 10.128.239.57 directly interacted with 10.128.239.37 over SMB and related internal protocols, including:

- access to \\10.128.239.37\IPC$
- access to \\10.128.239.37\ADMIN$
- NetrShareEnum share enumeration activity
- SMB file operations involving delete.me

These records directly link 10.128.239.57 and 10.128.239.37 in the preparation phase before exfiltration and support the assessment that 10.128.239.37 likely served as an internal staging-related host.

However, Zeek does not independently prove that 10.128.239.37 was the definite compression host or that it explicitly created the archives later uploaded externally. That stronger compression-host claim remains better supported by PCAP evidence.

Table C5: Staging-Related SMB Evidence

Timestamp (UTC)	Source IP	Destination IP	Protocol / Log Type	Artifact	Meaning
2025-03-01 23:30:37Z	10.128.239.57	10.128.239.37	SMB mapping	\\10.128.239.37 \IPC$	.57 accessed IPC share on .37
2025-03-01 23:30:45Z	10.128.239.57	10.128.239.37	SMB mapping	\\10.128.239.37 \ADMIN$	.57 accessed administrative share on .37
2025-03-01 23:30:45Z	10.128.239.57	10.128.239.37	DCE/RPC	NetrShareEnum	.57 enumerated shares on .37

2025-03-01 23:30:49Z	10.128.239.57	10.128.239.37	SMB file activity	delete.me	.57 opened and deleted a file on .37

C.6 Compression-Related Evidence

Zeek provides partial support for the hypothesis that compression or archive preparation occurred before exfiltration.

First, Zeek shows 10.128.239.57 accessing 7-Zip-related software paths on 10.128.239.47, including:

- Program Files\7-Zip
- Program Files\7-Zip\Lang

These were recorded as SMB file-open events and indicate that 7-Zip tooling was present and accessed in the internal environment during suspicious activity.

Second, Zeek also shows 10.128.239.57 accessing multiple .zip archive files over SMB, including archive-like material on 10.128.239.37. This supports the interpretation that compressed archive material was involved in internal file handling during staging.

However, Zeek does not directly reveal:

- a .7z filename
- a 7-Zip executable such as 7z.exe, 7za.exe, or 7zr.exe
- an explicit archive-creation event
- direct proof that the final outbound payload was specifically packaged as .7z

Therefore, Zeek supports compression-related activity in general, but the more specific .7z-archive claim remains better evidenced by PCAP.

Table C6: Compression-Related Zeek Evidence

Timestamp (UTC)	Source IP	Destination IP	Protocol / Log Type	Artifact	Meaning
2025-03-06 23:26:25Z	10.128.239.57	10.128.239.47	smb_files	Program Files\7-Zip	.57 accessed a 7-Zip program directory
2025-03-06 23:26:25Z	10.128.239.57	10.128.239.47	smb_files	Program Files\7-Zip\Lang	.57 accessed a 7-Zip subdirectory
2025-03-06 staging window	10.128.239.57	10.128.239.37	smb_files	multiple .zip files	.57 accessed compressed archive files on .37
targeted final search	10.128.239.57	10.128.239.37	mb_files / smb_mapping	ADMIN$, <share_root>, delete.me	confirms file-handling/staging behavior, but no .7z filename found

C.7 Encryption and Visibility Limitations

Despite strong evidence of exfiltration, Zeek cannot directly reveal the exact contents of the outbound transfer. This is because the upload to temp.sh occurred over TLS/HTTPS on port 443, which encrypted the application payload. As a result:

- no raw HTTP POST body was visible

- no direct archive magic bytes from the outbound encrypted stream could be confirmed through Zeek alone
- the exact final uploaded file set cannot be reconstructed with certainty from Zeek metadata alone

Accordingly, Zeek is strongest for proving:

- destination
- transport protocol
- volume
- timing
- staging-related behavior

but not for fully recovering the final encrypted payload contents.

C.8 Conclusion

The Zeek-based investigation confirms that 10.128.239.57 exfiltrated approximately 1.03 GB of data to temp.sh / 51.91.79.17 over TLS/443, providing strong evidence of large-scale encrypted outbound data theft. Zeek corroborates the exfiltration chain at multiple layers by showing:

1. DNS resolution of temp.sh to 51.91.79.17
2. outbound TLS sessions from 10.128.239.57 to 51.91.79.17:443
3. at least one TLS record with server.name = temp.sh
4. approximately 1.03 GB of outbound data volume
5. internal SMB-based staging activity involving 10.128.239.37
6. compression-related evidence, including 7-Zip-related path access and multiple .zip archive accesses

At the same time, Zeek does not independently prove that the final uploaded payload was specifically a .7z archive, nor does it fully reconstruct the exact contents of the encrypted outbound transfer. The most defensible interpretation is therefore that Zeek strongly confirms the core exfiltration chain and supports compression/staging-related activity, while the more specific claims about .7z archives, compression-host directionality, and the full phased long-range timeline are more strongly established by PCAP analysis.

D. Payload Deployment

Assigned to: Jess, Joy, Nicholas (Team 1)

[TO BE COMPLETED BY TEAM 1]

[Explain: how the ransomware was deployed]

[Identify: affected systems]

[Hint: If attacker controls the DC, did they use RDP to manually drop the file on servers?]

[Look for: file transfers via SMB2, executable artifacts, RDP sessions to backup servers]

[Include MITRE ATT&CK mapping]

D.1 Overview

The attacker deployed ransomware across the internal network using a coordinated approach involving lateral movement, remote execution, and administrative access.

Initial access was established via an inbound RDP connection to the host 10.128.239.57, which was acting as a distribution node under attacker control via RDP.

From the analysis of the alerts file, suspicious inbound RDP traffic was identified coming from an external IP (206.189.231.47) to the host(10.128.239.57) on 2025-03-07. The relevant alerts are shown below:

Time	Source IP	Destination IP	Description
2025-03-7T23:51:07.152Z	206.189.231.47	10.128.239.57	ET REMOTE_ACCESS Inbound RDP Connection with TLS Security Protocol Requested
2025-03-7T23:51:22.543Z	206.189.231.47	10.128.239.57	ET REMOTE_ACCESS Inbound RDP Connection with Minimal Security Protocol Requested
2025-03-7T23:51:22.595Z	206.189.231.47	10.128.239.57	ET REMOTE_ACCESS Inbound RDP Connection with Minimal Security Protocol Requested

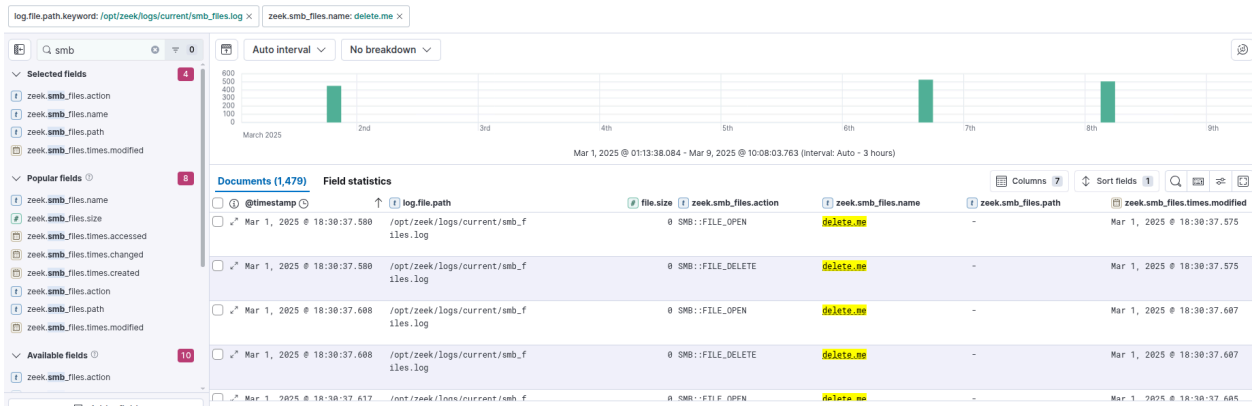
From these alerts, we suspect that the attacker logged in via RDP into the network from 206.189.231.47 and managed to obtain control of 10.128.239.57. This host was then used for subsequent activity, including lateral movement and payload delivery, acting as the primary control point.

Following the RDP session, the attacker leveraged multiple techniques, including SMB-based file transfers, WinRM remote execution, and RDP sessions to propagate and execute the payload across multiple systems. This combination of techniques suggests both automated deployment and manual attacker involvement.

D.2 How was the Payload Deployed

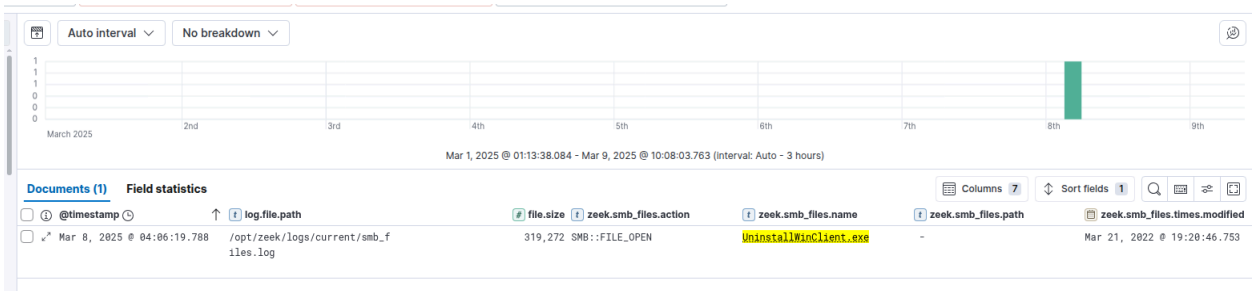
The attacker deployed the payload using a hybrid method of RDP sessions, SMB file activities and controlling the Domain controller using WinRM

Zeek logs identified repeated SMB connections from 10.128.239.57 to multiple internal hosts, with access to administrative shares such as IPC$, ADMIN$, and C$. These shares allow remote file operations, including file upload, execution, and deletion.



On 6th March, we noticed a significant spike of 1499 SMB actions, which indicates scripted or automated deployment rather than normal manual use. During this period, files named “delete.me” were repeatedly created and deleted across multiple hosts. This behaviour suggests that the attacker was testing write access, validating connectivity, and preparing the environment before deploying the actual payload.

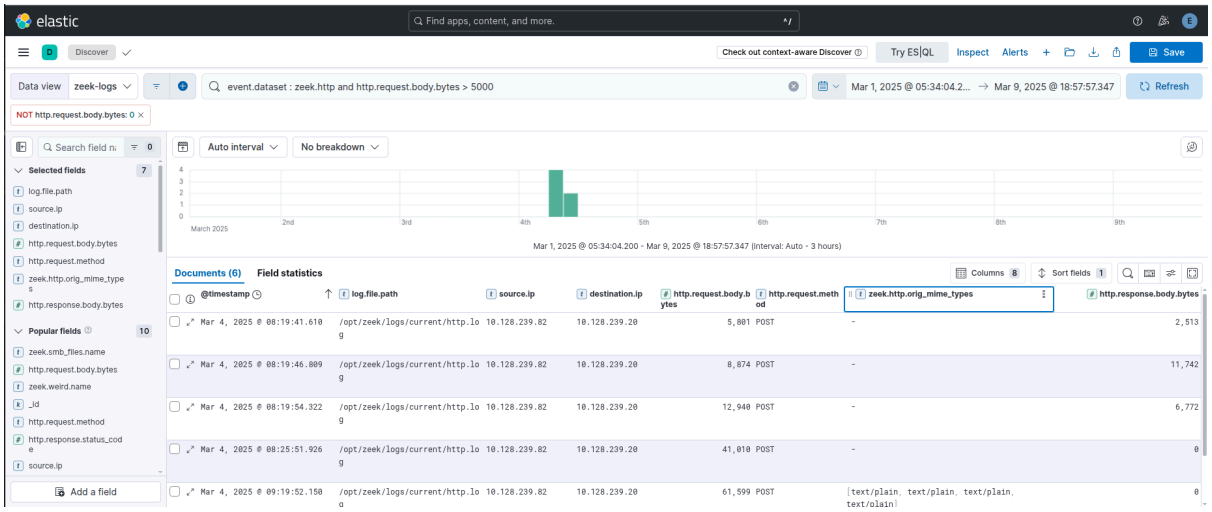
Further Zeek analysis showed that the “delete me “ files were accessed using ADMIN$ credentials on 6 March. This reinforces the conclusion that the attacker had administrative privileges and was performing controlled testing of access across the network.
This behaviour aligns with MITRE ATT&CK: T1570 - Lateral Tool Transfer



Besides 6th March, we noticed a spike in SMB activities on 8th March. During this period, an unusual executable file “UninstallWinClient.exe” was found. This file seems to be associated with a cybersecurity monitoring tool called Netwrix. The presence of this executable file suggests that the attacker was trying to disable or remove endpoint protection before deploying the ransomware payload.
This behaviour aligns with MITRE ATT&CK: T1562.001 - Disable or Modify Tools

Immediately after this executable file was accessed, we noticed multiple file paths under /Program Files (x86)/ and /Users/ were opened. This suggests that the attacker was performing reconnaissance on the system and user directories to understand the environment and prepare for payload execution.
This behaviour aligns with MITRE ATT&CK: T1083 – File and Directory Discovery

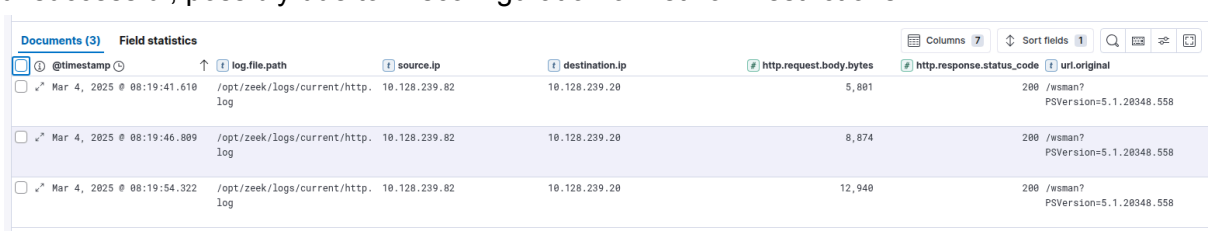
D3 WINRM & Domain Controller



Analysis of network traffic revealed that the attacker used multiple methods to coordinate payload execution.
A sequence of large HTTP POST requests over WinRM (port 5985) from host 10.128.239.82 to the Domain Controller (10.128.239.20) indicates repeated remote PowerShell execution. The increasing payload sizes (up to ~61 KB) and the repeated-execution pattern strongly suggest staged command delivery, consistent with ransomware payload deployment.

Additionally, we noticed repeated outbound HTTP POST requests initiated by host 10.128.239.57 to go.microsoft.com (23.61.14.152), using the User-Agent "MICROSOFT_DEVICE_METADATA_RETRIEVAL_CLIENT".These requests targeted a fixed endpoint and were executed in rapid succession. However, all requests received HTTP 403 Forbidden responses, indicating unsuccessful communication.

This behavior deviates from normal Microsoft metadata retrieval patterns and suggests possible command-and-control (C2) beaconing or payload staging attempts. The repeated failed requests imply that the malware was attempting to establish external communication but was unsuccessful, possibly due to misconfiguration or network restrictions.



We uncovered WinRM traffic from 10.128.239.82 to 10.128.239.20 (port 5985). The destination hostname jjjjjjjdc1.domain-ees3Ai.local suggests 10.128.239.20 is a Domain Controller (DC). This means the attacker likely used WinRM for remote command execution—a common lateral movement technique (MITRE T1021.006).

Combining these observations, the ransomware deployment was carried out using a hybrid approach:

- WinRM for centralized command execution via the Domain Controller
- SMB for payload distribution across endpoints
- RDP for manual execution and validation

This coordinated approach allowed the attacker to distribute the ransomware across multiple systems and ensure it was successfully executed on each host.

D4 Payload Transfer

Next, looking at the internal traffic:

Time	Source IP	Destination IP	Description
2025-03-08T09:06:19.788Z	10.128.239.57	10.128.239.66:445	ET INFO SMB2 NT Create AndX Request For an Executable File
2025-03-08T09:06:19.799Z	10.128.239.57	10.128.239.66:445	ET INFO SMB2 NT Create AndX Request For an Executable File
2025-03-08T09:06:19.855Z	10.128.239.57	10.128.239.66:445	ET INFO SMB2 NT Create AndX Request For an Executable File

From these logs, we believe that the attacker used SMB2 to push an executable file from 10.128.239.57 to 10.128.239.66:445. The fact that these executable-related SMB requests occurred repeatedly within the same second is significant, which is not consistent with normal user activity for accessing files. This suggests scripted or automated deployment behaviour, where the attacker pushes executable content to the target host in a controlled and repeatable way. This is consistent with the use of SMB administrative shares for lateral payload distribution, and aligns with MITRE technique T1570 (Lateral Tool Transfer)

This activity is further supported by earlier SMB behaviour from 10.128.239.57, which showed access to remote shares on the destination host, including IPC$, ADMIN$, and C$. The observed sequence, beginning with share access and followed by executable-related file operations, indicates that the attacker had authenticated administrative access and used it to stage files remotely before execution. In the context of the wider attack chain, this strongly supports the assessment that 10.128.239.57 acted as the main payload distribution node inside the network.

On 8th March 2025, around 08:22Z, a second coordinated SMB wave from the same host was also observed. This is important as it reinforces the conclusion that 10.128.239.57 was not simply another infected host, but rather the attacker's main internal pivot used to distribute tooling and deploy the ransomware across other systems. The repeated return to SMB-based

activity from the same source host suggests deliberate operator control and staged deployment rather than a single isolated transfer event.

Further analysis of PCAP data revealed additional suspicious payload-related filenames, including:

- kkwlo.exe
- hfs.exe
- hfsips.txt

These filenames were identified by scraping readable strings from raw PCAP data during the 6 March SMB deployment period. Although the full binaries could not be extracted from the traffic, the presence of these unusual executable and support-file names in SMB-related traffic is highly suspicious. They are not typical Windows system files, and their appearance during a period of intense lateral SMB activity strongly suggests that they were part of the attacker's deployment toolkit or ransomware payload set. In particular, the presence of both executable files and an accompanying text file suggests that the attacker may have been transferring not only payload binaries, but also supporting configuration or targeting information used during execution.

Taken together, these findings indicate that payload transfer was carried out through SMB-based lateral tool transfer, with 10.128.239.57 pushing suspicious executables to internal systems using administrative shares. This behaviour is consistent with MITRE ATT&CK T1570, Lateral Tool Transfer, where adversaries move malicious tools or payloads from one compromised system to another in preparation for execution.

D5 Affected Systems

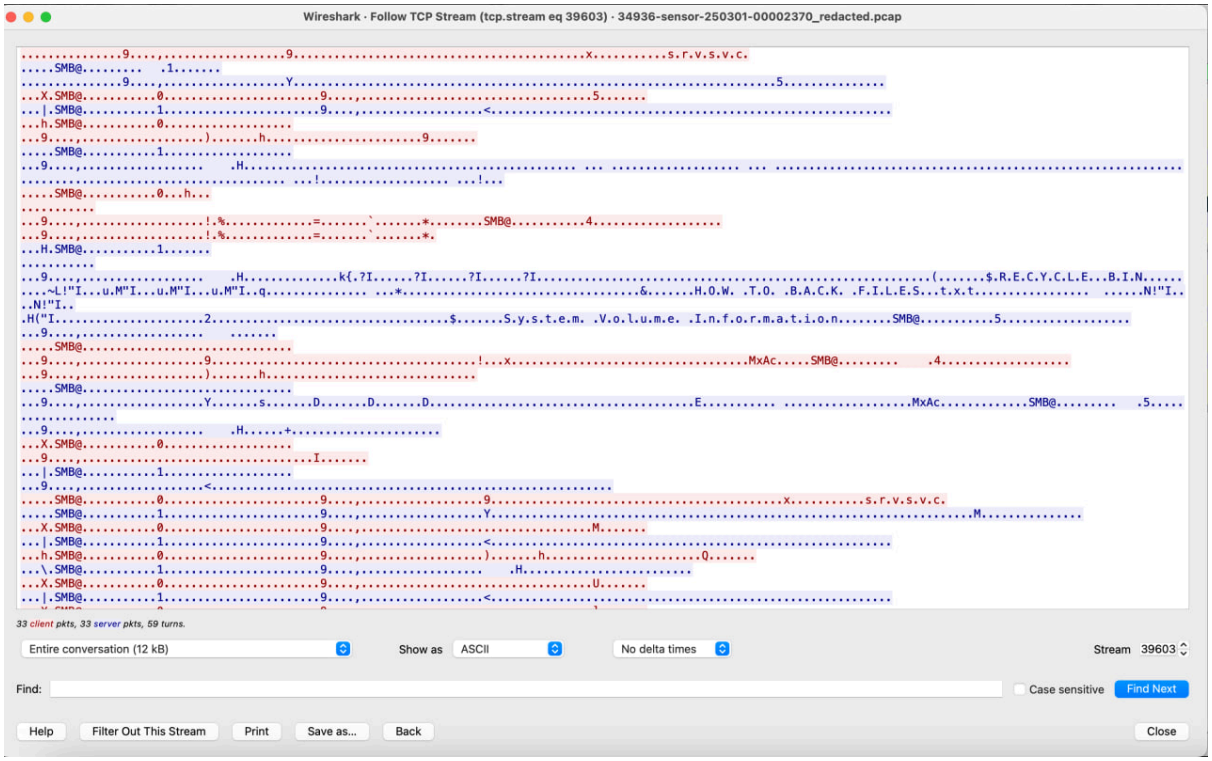
The ransomware deployment affected multiple systems across the internal network.

- delete.me file affected 49 endpoints
- 10.128.239.66 was confirmed to have received executable payload files via SMB
- 10.128.239.57 initiated connections to multiple internal systems via RDP. These connections were encrypted, indicating successful RDP session establishment.

D6 Impact (Final Encryption)

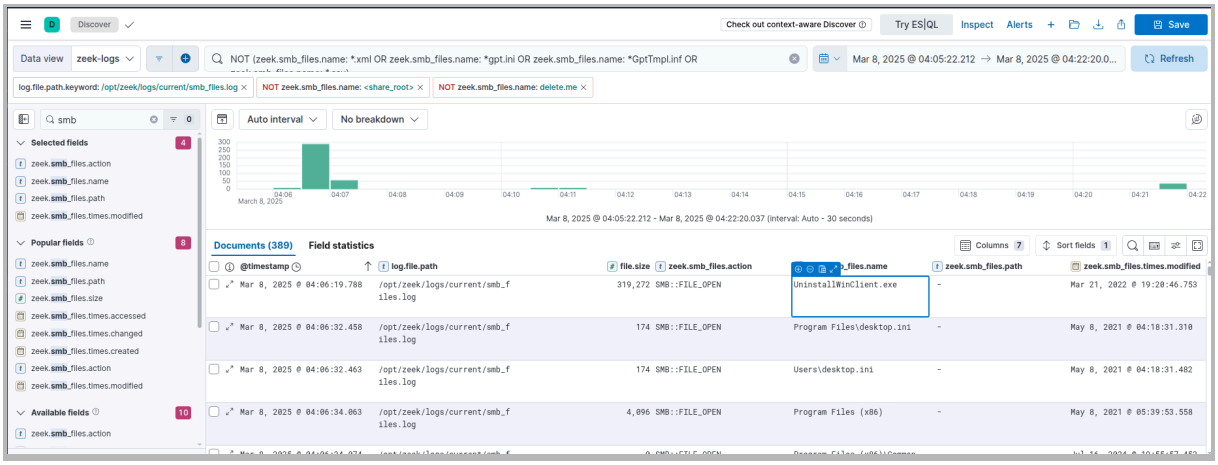
We identified the presence of a ransom note file “HOW TO BACK FILES.txt” after scraping the PCAP files for readable UTF-16 strings. This file was discovered in SMB traffic as part of directory listings. Although the file could not be extracted due to the absence of a file read or download operation, its presence confirms that encryption had already taken place on affected systems. A ransom note filename appearing in a directory response indicates that the file had already been created on the remote system and was visible in the filesystem at the time of capture. This provides strong evidence that the ransomware had already executed and left behind its post-encryption note.

The deployment of ransom notes across the network indicates that the attacker successfully executed the payload and completed the encryption phase of the attack.



—------

Other information that we have so far but have yet to summarise:
We notice an unusual file being opened → “UninstallWinClient.exe”

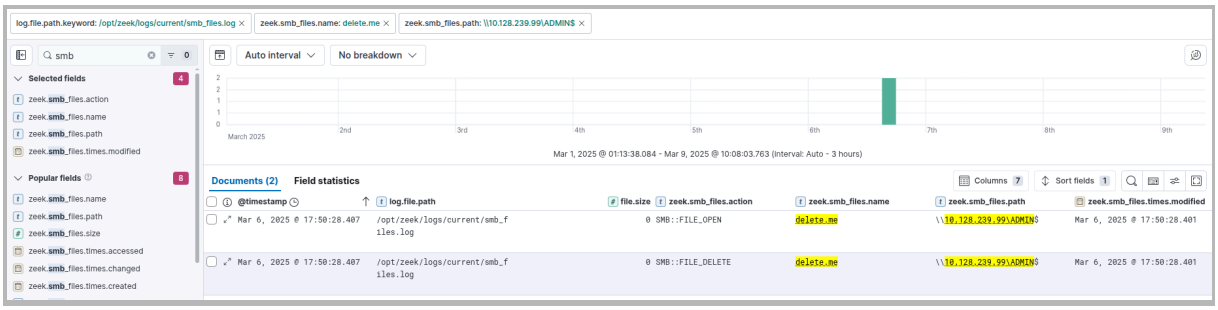


We note that immediately after this .exe file was downloaded, the few file paths that were opened using SMB were all /Program Files (x86)/ , followed by /User/ paths
It seems like the “UninstallWinClient.exe” could have been an uninstaller for some security software to disable endpoint protection (patient zero)
This maps to MITRE ATT&CK: T1562.001 – Disable or Modify Tools.

Opening up numerous files under /Program Files (x86)/ and /Users/ could have been reconnaissance to understand where to deploy the payload and what sensitive information can be stolen/encrypted.
MITRE ATT&CK: T1083 – File and Directory Discovery

We uncovered WinRM traffic from 10.128.239.82 to 10.128.239.20 (port 5985). The destination hostname jjjjjjdc1.domain-ees3Ai.local suggests 10.128.239.20 is a Domain Controller (DC). This means the attacker likely used WinRM for remote command execution—a common lateral movement technique (MITRE T1021.006).

**we have yet to find the actual payload → initially thought it was “UninstallWinClient.exe” but after some consideration it might not be



The "delete.me" file could likely be used by other legitimate processes, however we note that it is strange that there was a spike in the SMB logs for delete.me on 01-03, 06-03, and 08-03.

We further note that the "delete.me" file was accessed using ADMIN$ credentials on 06-03. This is likely the attacker testing write access, connectivity, or later clean up after deploying malware.

The attacker likely performed this quick test before actually deploying the payload. Hence, we focus our search to SMB activities after 06-03.

MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Evidence
Initial Access	T1133	External Remote Services	External RDP access to 10.128.239.57:3389, with inbound encrypted RDP/TLS activity followed by immediate internal Netlogon behavior; 96.126.120.149 remains the strongest single external session candidate.
Initial Access	T1078	Valid Accounts	RDP normally requires authentication, and the session characteristics are more consistent with successful authenticated use than with a failed probe.
Lateral Movement	T1021.001	Remote Services: RDP	RDP from .57 to .34, .35, .36, .37, .39, .176
Lateral Movement	T1021.002	Remote Services: SMB/Windows Admin Shares	SMB2 from .57 to ~20 internal hosts
Lateral Movement	T1021.003	Remote Services: DCOM	IOXIDResolver/ISystemActivator to .32
Discovery	T1135	Network Share Discovery	SRVSVC traffic from .57 to .176
Discovery	T1018	Remote System Discovery	SMB2 connections to multiple internal IPs
Collection	T1560	Archive Collected Data	Inferred: data may have been compressed
Exfiltration	T1567.002	Exfil Over Web Service: Cloud Storage	~458 MB uploaded to temp.sh via TLS 1.3
Impact	[TBD]	[TBD — Team 1]	[TBD]

Conclusion and Recommendations

[TO BE COMPLETED COLLABORATIVELY]

[Prioritized recommendations to address gaps and prevent recurrence:]

[1. Restrict RDP exposure — 10.128.239.57 had RDP open to hundreds of external IPs]

[2. Implement network segmentation — attacker moved freely via SMB2/RDP across ~20 machines]

[3. Block known exfiltration services — temp.sh should be blocked at the firewall/proxy]

[4. Enable TLS inspection — encrypted exfiltration was invisible to network monitoring]

[5. Deploy EDR — no endpoint telemetry was available during this incident]

[6. Implement MFA for RDP access]

[7. Monitor for anomalous SMB2 file access patterns]

Appendix — Timeline

Date / Time (UTC)	Phase	Activity
2025-3-1 18:20 - 20:07	Scanning/Brute Force	Earliest visible foothold behavior: inbound RDP to .57, immediate Netlogon to .29
2025-3-1 20:07:57	Initial Access	Successful interactive RDP session begins
2025-11-20 ~13:06	Staging	SMB2 Read Request from .57 to .37 (file server access begins)
2025-11-21 08:14:41	Exfiltration	First DNS query for temp.sh from 10.128.239.57
2025-11-21 08:14:58	Exfiltration	First TLS 1.3 connection to temp.sh (51.91.79.17)
2025-11-21 14:02–14:13	Exfiltration	Evening exfiltration session (3 connections)
2025-12-10 ~01:14	Lateral Movement	DRSUAPI activity — AD replication traffic between DCs
2026-01-27 02:31–04:20	Exfiltration	Second exfiltration window to temp.sh (5 connections, ~458 MB total)
[TBD — Team 1]	Payload	[Ransomware deployment]

Appendix — Timesheet & Work Breakdown

Team	Members	Section	Responsibility
Team 1	Jess, Joy, Nicholas	D. Payload Deployment	Ransomware deployment analysis
Team 2	Jasmine, Chun Wei, Hong Xun	A. Initial Access	Patient zero identification
Team 3	Phoebe, Yik Sheng, Liu Cong	B. Lateral MovementC. Exfiltration	Lateral movement analysis, exfiltration investigation, PCAP triage methodology
All	All members	Executive Summary, Conclusion	Collaborative writing and review

Appendix — Supporting Evidence

[Insert Wireshark screenshots here]

[Screenshots should include: DNS queries for temp.sh, TLS Client Hello sessions, TCP Conversations showing data volume, SMB2 filenames, DRSUAPI traffic, RDP connections from .57 to internal hosts]

Wireshark Filters Reference

Filter	Purpose
dns.qry.name contains "temp.sh"	Find DNS queries for exfiltration service
tls.handshake.extensions_server_name contains "temp.sh"	Confirm TLS connections via SNI
ip.addr == 51.91.79.17	All traffic to/from temp.sh IP
ip.addr == 51.91.79.17 && tls.handshake.type == 1	TLS session start times
tcp.dstport == 445 && tcp.flags.syn == 1	SMB scanning search (negative)
samr	User creation search (negative)
drsuapi	AD replication traffic
drsuapi.opnum == 3	DsGetNCChanges requests
ip.addr == 10.128.239.57	All traffic from compromised host
smb2.filename	SMB2 file access names

References

[1] MITRE ATT&CK Framework — https://attack.mitre.org/

[2] Lynx Ransomware Group Threat Intelligence — [INSERT SOURCE]

[3] temp.sh File Sharing Service — https://temp.sh

[Add additional references as needed]